Empirical Vulnerability Taxonomy of Autonomous AI Agent Frameworks: Cross-Origin OAuth Token Leakage, OpenAPI SSRF, and Sandbox Escape Vectors

Offensive Security Research & Responsible Disclosure Across Production LLM Agent Ecosystems

HM Shihabuddin Jashory (Shihab)
Principal AI Systems Architect & Security Researcher, Vision Flow Group (https://visionflowgroup.work)
Department of Computer Science, University of the People, Pasadena, CA, USA (Student ID: C211345610)
ORCID iD: https://orcid.org/0009-0003-4163-0092 ? Contact: shihabjessore7@gmail.com | jashory7@gmail.com

ABSTRACT

1. THREAT MODEL OF TOOL-AUGMENTED AI AGENTS

Modern AI agent frameworks dynamically ingest third-party OpenAPI specifications, Model Context Protocol (MCP) servers, and remote plugin manifests. When an agent holds privileged OAuth tokens or runs inside a cloud VPC with access to instance metadata services (169.254.169.254), improper header propagation or unvalidated URL fetching allows an attacker to exfiltrate credentials or pivot into internal infrastructure.

2. CLASS I: CROSS-ORIGIN OAUTH TOKEN LEAKAGE ON REDIRECT (ISSUE #577552191 / GHSA-5r5r-27w9-95

During our audit of agent transport layers, we identified that attaching static Authorization: Bearer <token> headers to HTTP clients that automatically follow 301/302/307 redirects causes sensitive OAuth tokens to be forwarded verbatim when a remote endpoint redirects to an untrusted cross-origin domain. Remediation requires stripping sensitive Authorization and Cookie headers whenever the redirect target's scheme, host, or port differs from the authenticated origin.

3. CLASS II: OPENAPI SPECIFICATION SSRF IN AGENT TOOL EXECUTION (ISSUE #579287563)

When an AI agent constructs executable REST tools from a user-supplied or dynamically retrieved OpenAPI spec, trusting the 'servers[0].url' field without private-IP / loopback / link-local egress filtering enables Server-Side Request Forgery (SSRF) against cloud metadata endpoints and internal microservices. We propose a zero-trust socket-level DNS resolution and CIDR blocklist filter prior to any agent-initiated HTTP request.

4. DEFENSE-IN-DEPTH RECOMMENDATIONS FOR AI AGENT ARCHITECTS

We formulate three mandatory security invariants for production AI agent runtimes: (1) Origin-bound credential attaching with strict redirect stripping, (2) Network-layer egress sandboxing blocking RFC 1918, RFC 4193, and link-local metadata ranges (169.254.0.0/16), and (3) Deterministic PreToolUse policy hooks that inspect tool arguments before execution.

© 2026 HM Shihabuddin Jashory (ORCID: 0009-0003-4163-0092) · Open Science License (CC-BY-4.0)

REFERENCES & VERIFIABLE ARTIFACTS

[1] Jashory, H. M. S. (2026). Google OSS VRP Issue #577552191 & GHSA-5r5r-27w9-95hh (OAuth Token Leakage Disclosure).
[2] Jashory, H. M. S. (2026). Google Issue Tracker #579287563 (google/adk-python OpenAPI RestApiTool SSRF Disclosure).
[3] Jashory, H. M. S. (2026). Google Issue Tracker #579179997 (Cloud Data Fusion cdapio/cdap Security Disclosure).
[4] Jashory, H. M. S. (2026). Eight Multi-Framework AI Security Advisories (LangChain, CrewAI, AutoGen, OpenHands, LiteLLM, Dify, vLLM).
[5] ORCID Scientist Profile: https://orcid.org/0009-0003-4163-0092

© 2026 HM Shihabuddin Jashory (ORCID: 0009-0003-4163-0092) · Open Science License (CC-BY-4.0)